

Emnekode:	ETH2100
Emnenavn:	Etisk Hacking
Vurderingskombinasjon:	Mappevurdering, DEL 3
Innleveringsdato:	20. desember 2024
Filformat:	PDF (ingen vedlegg)

Eksamen er en mappevurdering og består av 3 deler. Delene skal leveres som 3 forskjellige innleveringer i Wiseflow. Karakter blir satt basert på ALLE delene som en helhet, alle 3 delene må være bestått. Se første forelesning for detaljer om karaktersetting.

Del 3: EKSAMEN (14 dager, individuell, hjemmeeksamen)

- Eksamenstart 6. desember
- Innleveringsfrist 20. desember (se Wiseflow for tidspunkt)
- Eksamensoppgaven publiseres også på Canvas under «EKSAMEN» samme dag
- Besvarelsen leveres inn som PDF fil, det skal ikke leveres med vedlegg

Oppgavesettet består av 10 sider, og det er totalt 8 oppgaver som skal besvares.

Vær obs på at eksamen MÅ leveres innen fristen som er satt, og må leveres via eksamensplattformen WISEFLOW. Det vil ikke være mulig å få levert oppgaven etter fristen – det betyr at du bør levere i god tid slik at du kan ta kontakt med eksamenskontoret eller brukerstøtte hvis du har tekniske problemer.

Da dette er en hjemmeeksamen er det viktig å vise helhetlig forståelse, og oppgavene har et større preg av drøfting eller teknisk problemløsning. Det forventes derfor utfyllende og forklarende svar på alle teori oppgaver, og dokumentasjon i form av skjermbilder og tilhørende forklaringer til alle praktiske oppgaver. (Bilder som er vedlegg, men ikke satt inn i besvarelsen anses ikke som en del av besvarelsen.)

Det presiseres at studenten skal besvare eksamen selvstendig og individuelt, samarbeid mellom studenter og plagiat er ikke tillatt. Det er ikke tillatt å presentere andres arbeid som ditt eget – dette inkluderer arbeid utført av kunstig intelligens (som tekst- eller kode-genereringsmodeller). All bruk av tekst, bilder og illustrasjoner som er hentet fra forelesninger, lærebøker eller internett skal føres med kildehenvisning slik at det kommer tydelig frem hva som er studentens eget arbeid, APA7 standarden skal brukes for kilder. For topp score bør svarene underbygges med relevante kilder utover ordinær pensumlitteratur. Det bør selvsagt også refereres til pensumlitteratur når relevant.

OBS: De 4 teorioppgavene (oppgave 1 – 4) skal ikke være på mer enn 12 A4 sider, med font størrelse 12, normale marger og linjeavstand 1.0. I tillegg til teorioppgavene kommer de praktiske oppgavene (de praktiske oppgavene inngår ikke i sideantallet på 12 sider, som kun gjelder for teorioppgavene samlet).

Teori oppgaver og drøftinger

Oppgave 1 – Etisk hacking (10%)

For en som jobber innen informasjonssikkerhet er det viktig å forstå hva en etisk hacker er, hva en sikkerhetstest er, og hvordan rollen som etisk hacker passer inn i sikkerhetsorganisasjonen. En etisk hacker må være i stand til å forklare dette tydelig til forskjellige lag i organisasjonen, men også andre ansatte må kunne vite når og til hva man kan bruke etiske hackere, enten innleid eller i egen organisasjon.

Svaret må underbygges med relevante kilder. Besvarelser som ikke har korrekt oppgitt kildereferanse på APA7 format vil ikke oppnå poeng. Kildelisten skal oppgis for hver deloppgave separat.

Oppgaveformulering:

Du har nettopp startet i ny jobb i avdelingen for IT sikkerhet i et stort konsultentselskap. Forklar for en (tenkt) arbeidsgiver hvorfor selskapet burde tilby sine kunder å gjennomføre en «penetrasjonstest» av sine selskap. Forklar hva en etisk hacker betyr, hva et etisk hackers rolle er, og hvordan dette spiller inn i en sikkerhetsorganisasjon.

Oppgave 2 – Cyberspace (5%)

«Cybersikkerhet» tar mer og mer over som begrep for å forklare vår bransje, som også navnet på dette studiet viser, det er derfor viktig å forstå hva som ligger i dette begrepet, og å kunne drøfte forskjellene mellom begreper som «cyberspace» og «internett».

Svaret må underbygges med relevante kilder. Besvarelser som ikke har korrekt oppgitt kildereferanse på APA7 format vil ikke oppnå poeng, en av kildene må være «Forsvarets fellesoperative doktrine» og begrepene brukt der må drøftes opp mot andre kilder. Kildelisten skal oppgis for hver deloppgave separat.

Oppgaveformulering:

Drøft begrepene «cyberspace» og «cybersikkerhet», forklar bakgrunnen for begrepene og forklar hvorfor dette begrepet er viktig i rollen til en etisk hacker.

Oppgave 3 – Fysiske enheter (15%)

Når man skal gjennomføre en mer avansert red team øvelse kan det være interessant å bruke fysiske enheter som en del av angrepssimuleringen. For en etisk hacker er det derfor essensielt å ha god oversikt over de forskjellige verktøyene som er tilgjengelig for å kunne forstå hvilke som er best egnet til forskjellige oppgaver. I denne oppgaven skal du vise at du klarer å omsette det du har lært om avanserte angrepssimuleringer og fysiske verktøy til en helhetlig plan om bruk av slike verktøy.

På denne oppgaven må besvarelsen inneholde minimum en referanse til relevant kapittel i pensumlitteraturen, minimum en referanse til en youtube video som forklarer bruk av en av enhetene du har valgt å bruke (minutt og sekund inn i videoen skal oppgis), og minimum en annen referanse. Besvarelser som ikke har korrekt oppgitt kildereferanse på APA7 format vil ikke oppnå poeng. Kildelisten skal oppgis for hver deloppgave separat.

Oppgaveformulering:

Denne oppgaven er todel. I den første delen skal du sammenstille en tabell som inneholder minimum 6 fysiske enheter som er spesielt godt egnet for / laget konkret for avansert angrepssimulering eller penetrasjonstesting. Tabellen skal inneholde følgende informasjon; navn på enheten, pris på enheten, URL til hvor enheten kan kjøpes inn, og en kort beskrivelse av enhetens bruksområde (30 – 60 ord).

I den andre delen av oppgaven skal du lage og beskrive en plan for å gjennomføre en red team øvelse med fysisk element, i denne planen skal du forklare hvordan du kan bruke disse fysiske enhetene som beskrevet over (minimum 4 av enhetene skal brukes). For å få best poengoppnåelse på denne oppgave bør planen enten kombineres med social engineering på en fornuftig måte, eller enhetene bør brukes i et «kjedet angrep» hvor hver fase bruker en enhet og bygger på resultatet i tidligere fase. Planen bør være så konkret som mulig og rette

seg mot et anerkjent norsk selskap – men det presiseres at angrepet ikke skal gjennomføres eller testes i praksis (dette er den teoretiske delen av eksamen).

Oppgave 4 – Analyse av hacker angrep (20%)

Som en etisk hacker vil man ofte bli bedt om en ekspertuttalelse om et hacker angrep som har fått fokus i media, du skal i denne oppgaven derfor vise at du er i stand til å tilegne deg ny kunnskap, sette dette i kontekst til en angriper/hacker, og forklare dette videre med egne ord.

I denne oppgaven skal du vise at du klarer å fordype deg i et emne, og raskt finne kilder med relevant informasjon.

På denne oppgaven må besvarelsen inneholde minimum en referanse til artikkelen som er linket under og minimum to andre referanser. Besvarelser som ikke har korrekt oppgitt kildereferanse på APA7 format vil ikke oppnå poeng. Kildelisten skal oppgis for hver deloppgave separat.

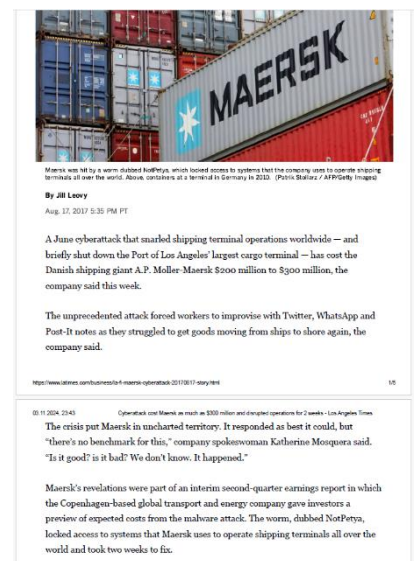
En oppdragsgiver sender deg følgende artikkel fra Los Angeles Times, forfattet av Jill Leovy 17. august 2017 (artikkelen er også lagt ved eksamensoppgaven på Canvas som PDF fil):

<https://www.latimes.com/business/la-fi-maersk-cyberattack-20170817-story.html>

Oppgaveformulering:

Sett deg inn i hacker angrepet som rammet Maersk i 2017, som det vises til i artikkelen over. Du som teknikker må også søke flere mer tekniske kilder på egenhånd og skrive en fylldig beskrivelse av angrepet. Din beskrivelse bør inneholde informasjon om HVORDAN angrepet ble gjennomført, HVEM som stod bak angrepet, og HVA som ble skadefølgene av angrepet.

Du skal videre forklare for den tenkte oppdragsgiveren minimum 3 tiltak for å sikre at oppdragsgiver ikke (enkelt) blir offer for et tilsvarende angrep.



Praktiske oppgaver

Oppgave 5 – Exploit med Metasploit (10%)

I denne oppgaven skal du vise at du kan gjennomføre et enkelt angrep med et exploit fra metasploit mot en sårbar server. Du skal demonstrere de faktiske verktøyene du bruker og dokumentere hvordan du har gått frem for å løse oppgaven, inklusive skjermbilder og kommandoer du har kjørt.

I denne oppgaven skal du bruke maskin med Kali Linux og Metasploit. Som «offer» maskin skal du bruke den virtuelle maskinen Metasploitable 2. Metasploitable 2 VMen skal være satt opp i henhold til øvingsoppgave i uke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verk_tøy).

Oppgaveformulering:

Du skal først starte Metasploitable 2 VM. Denne oppgaven består av 3 steg.

Det første steget er at du skal kjøre NMAP mot alle porter på Metasploitable 2, og vise hvilken VERSJON av FTP server som kjører på den VMen. Dokumenter med skjermbilde av NMAP og forklar hvilket versjonsnummer du har funnet.

I steg to skal du fra Kali Linux starte verktøyet Metasploit, du skal ved hjelp av Metasploit starte et shell på «offer» maskinen, og opprette en ny bruker. Brukernavnet skal være DITT kandidatnummer på denne eksamen, og med et valgfritt passord. *Du oppretter en ny bruker ved å skrive «useradd -m 999» etterfulgt av «passwd 999» for å sette passord for brukeren, hvor 999 erstattes av DITT kandidatnummer på denne eksamen.*

I det tredje steget skal du restarte Metasploitable 2 VMen og logge deg inn med den nyopprettede brukeren, dokumenter med skjermbilde av Metasploitable 2 at du har fått opprettet ny bruker.

Oppgave 6 – Mimikatz og passordangrep (10%)

I denne oppgaven skal du vise at du kan gjennomføre et passord angrep mot en Windows maskin. Angrepet knekker passord for en kompromittert bruker.

I denne oppgaven skal du bruke maskin med Kali Linux. Som «offer» maskin skal du bruke den virtuelle maskinen «Bengts Windows VM». Windows VMen skal være satt opp i henhold til øvingsoppgave i uke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktoy), slide 64 til 78. I tillegg skal VMen ha tilleggsprogramvare og konfigurasjon som satt opp i:

- uke 42 (ETH2100_U42_Øvingsoppgaver_IntoTheRabbitHole_Exploits), slide 8 til 10,
- uke 44 (ETH2100_U44_Øvingsoppgaver_PasswordEqualsGod) slide 6 til 12, og
- uke 45 (ETH2100_U45_Øvingsoppgaver_DeepIntoTheRabbitHole) slide 7 til 25.

Oppgaveformulering:

Du skal starte opp Windows VM, og logge deg inn som Administrator. Denne oppgaven består av 3 steg.

Det første steget er at du skal opprette en ny bruker. Brukernavnet skal være bokstaven T etterfulgt av DITT kandidatnummer på denne eksamen, og passordet skal settes til sunshine.

I steg to skal du logge deg inn som den nye brukeren, og laste ned og kjøre verktøyet Mimikatz på Windows VMen.

I det siste steget skal du kopiere output fra Mimikatz over til Kali Linux, og i Kali skal du bruke verktøyet John the Ripper til å knekke passordet basert på brukerens NTLM hash.

Hvert steg i prosessen må dokumenteres med skjermbilder, skjermbildene må settes inn på korrekt sted i besvarelsen og prosessen må forklares med tekst.

— — — — —

Oppgave 7 – XSS angrep med BeeF (15%)

I denne oppgaven skal du vise at du kan gjennomføre et standard angrep med Browser Exploitation Framework (github.com/beefproject/). I en enkel pentest er det normalt å kun bevise at XSS angrep fungerer ved å kjøre et enkelt Javascript (for eksempel en alert), men i en mer omfattende Red Team øvelse er det ofte nødvendig å faktisk hente ut informasjon fra offerets maskin, eller plante en bakdør eller en trojaner. BeeF er et rammeverk som kan være et mulig valg for å få mer ut av en XSS sårbarhet.

Du skal demonstrere at du mestrer oppsett, konfigurasjon og deployering av BeeF verktøyet, og du skal dokumentere hvordan du har gått frem for å løse oppgaven, inklusive skjermbilder og kommandoer du har kjørt.

I denne oppgaven skal du bruke maskin med Kali Linux, og du skal bruke webserveren Damn Vulnerable Web Application (og undersiden "XSS Reflected", med security satt til Low), og som «offer» kan du velge å bruke din egen fysiske host maskin (eller en annen VM hvis du foretrekker det). DVWA VMen skal være satt opp i henhold til øvingsoppgave i uke 35 (ETH2100_U35_Øvingsoppgaver_Kali_VirtLab.pptx).

Oppgaveformulering:

Du skal sette opp BeeF på din Kali maskin (hvis du ikke allerede har det), og sette opp et Reflected XSS angrep mot webserveren. Fra «offer» maskinen skal du starte en nettleser og gå til den XSS-sårbare webserveren.

Du skal redigere config.yaml filen til BeeF og endre navnet på hook_file til å være ditt kandidatnummer på denne eksamen – etterfulgt av filendingen ".js", slik (eksempel for kandidat nummer 10042):

```
# Hook
hook_file: "/10042.js"
hook_session_name: "BEEFHOOK"
```

I besvarelsen skal du vise oppstart og kjøring av BeeF, du skal dokumentere hvordan du utfører XSS angrepet, og du skal vise både skjermbilde av BeeF som kjører på Kali, og du skal vise at du kobler deg på administrasjonsgrensesnittet til BeeF og klarer å se at «offer»

maskinen har blitt hacket. I BeeF skal du vise at du får opp browseren din som et offer, og du skal ta en skjermbilde av Details fanen som viser verdiene browser.window.origin, browser.window.cookies og browser.window.hostname. Hva er offerets PHPSESSIONID?

Oppgave 8 – Pivoting og PrivEsc (15%)

I denne oppgaven skal du vise at du kan gjennomføre et avansert angrep hvor du skal gjennomføre «pivot» (lateral movement) for å flytte deg fra den første sårbare serveren til en annen server på innsiden av nettverket. Du skal også oppnå «Manager» rettigheter.

Du skal videre demonstrere at du klarer å håndtere verktøy som kan brukes i et redteam oppdrag for å unngå at du blir oppdaget av sensorene til et Security Operations Center.

Oppgaven består av flere faser, og det er spesifikke krav til hver fase for å simulere angrepet, du skal demonstrere de faktiske verktøyene du bruker og dokumentere hvordan du har gått frem for å løse oppgaven, inklusive skjermbilder og kommandoer du har kjørt. Hvert del skal ha en underoverskrift i besvarelsen som «Del A», «Del B» og så videre, og fasene bygger på hverandre som gjør at de må gjøres i riktig rekkefølge.

I denne oppgaven skal du bruke maskin med Kali Linux. Som «offer» maskin «nummer 1» skal du bruke den virtuelle maskinen «Bengts Windows VM». Windows VMen skal være satt opp i henhold til øvingsoppgave i uke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktoy), slide 64 til 78. I tillegg skal VMen ha tilleggsprogramvare og konfigurasjon som satt opp i:

- uke 42 (ETH2100_U42_Øvingsoppgaver_IntoTheRabbitHole_Exploits), slide 8 til 10,
- uke 44 (ETH2100_U44_Øvingsoppgaver_PasswordEqualsGod) slide 6 til 12, og
- uke 45 (ETH2100_U45_Øvingsoppgaver_DeepIntoTheRabbitHole) slide 7 til 25.

Som «offer» maskin «nummer 2» skal du bruke den virtuelle maskinen som var brukt i arbeidskravet (Arbeidskrav VM). Arbeidskrav VMen skal være satt opp i henhold til oppgaven i uke 37 (ETH2100_U37_Arbeidskrav_ETH2100).

Disse to virtuelle maskinene må være koblet til det samme nettverket, og standard oppsett for VmWare forventes brukt (hvor VmWare simulerer en multiport repeater tilsvarende slik en Hub fungerer). Hvis du har gjort tilpasninger eller endringer i nettverksoppsettet du bruker i ditt lab-miljø må du ta hensyn til dette for å være i stand til å fullføre oppgaven.

Oppgaveformulering:

DEL A (første fase i angrepet)

Du skal starte opp Windows VM, og logge deg inn som Administrator. Denne virtuelle maskinen er sårbar ovenfor en sårbarhet som heter EternalBlue.

Det første steget er at du skal kjøre NMAP mot VM for å sjekke om serveren er sårbar ovenfor EternalBlue sårbarheten (hint: et script i nmap kan gjøre dette).

Fra Kali Linux skal du starte verktøyet Metasploit, du skal gjennom Metasploit utnytte EternalBlue sårbarhet på Windows VMen. Du skal utnytte sårbarheten til å sette opp remote execution (psexec), eller et reverse shell mot serveren.

DEL B (andre fase i angrepet)

Du skal så finne et verktøy som allerede er installert i Windows som kan utnyttes for å gjennomføre Packet Capture på nettverket. Dette skal ha tilsvarende effekt som å installere Wireshark – men det spesifiseres at studenten ikke har lov til å laste ned Wireshark på Windows VMen (og heller ikke bruke Wireshark hvis studenten har installert det der allerede under øvingstimene – i denne simuleringen vil bruk av Wireshark i denne delen trigge en alarm). Dette verktøyet skal settes i capture modus, og verktøyet må startes gjennom Metasploit fra Del A.

DEL C (simulering av aktivitet fra bruker)

Du skal så starte opp Arbeidskrav VMen, og du skal koble deg til webserveren med en nettleser. Nettleseren skal kjøre på Windows VMen (da det er pivot fra denne maskinen vi nå simulerer), på Windows VMen har du selv satt passord for Administrator bruker (det er tinkerbell hvis du har samme passord som satt i øvingsoppgavene). Fra Windows VM skal

du koble deg til web serveren på Arbeidskrav VMen, klikke Login, og logge deg inn med brukernavn mnguyen og passordet 27sfbdi.

Vær obs på at for å få brukt Internet Explorer på Windows VMen kan det anbefales å skru av Enhanced Security, hvis du ikke allerede har gjort dette.

DEL D (tredje og siste fase i angrepet)

For å avslutte angrepet skal du nå hente ut Packet Capture fra Windows VMen, det må gjøres gjennom Metasploit du brukte i Del A, men ellers er fremgangsmåten valgfri. Det er opp til deg hvordan du ønsker å gjøre det og hvor du ønsker å eksfiltrere data til – men det presiseres at det må gjøres gjennom Metasploit (og for eksempel ikke ved å logge inn «fysisk» på Windows.)

Du skal konvertere denne Packet Capture filen til å bli kompatibel med PCAP filformatet, og skal så åpne filen i Wireshark. Dette kan gjøres på host maskinen eller i Kali Linux. I Wireshark skal du finne HTTP pakken som inneholder innloggingen og dokumentere med skjermbilde at du har funnet passordet i klartekst – og med det demonstrere at du har gjennomført elevering av privilegier (til Manager rollen på offer «maskin 2»).

-

Slutt på oppgavesettet

Emnekode:	ETH2100
Emnenamn:	Etisk hacking
Vurderingskombinasjon:	Mappevurdering, DEL 3
Innleveringsdato:	20. desember 2024
Filformat:	PDF (ingen vedlegg)

Eksamen er ei mappevurdering og består av 3 delar. Delane skal leverast som 3 ulike innleveringar i Wiseflow. Karakter blir sett basert på ALLE delane som ein heilskap, alle 3 delane må vere beståtte. Sjå første førelesing for detaljar om karaktersetjing.

Del 3: EKSAMEN (14 dagar, individuell, heimeeksamen)

- Eksamenstart 6. desember
- Innleveringsfrist 20. desember (sjå Wiseflow for tidspunkt)
- Eksamensoppgåva blir òg publisert på Canvas under «EKSAMEN» same dag
- Svaret leverast inn som PDF-fil, det skal ikkje leverast med vedlegg

Oppgavesettet består av 10 sider, og det er totalt 8 oppgåver som skal svarast på.

Ver obs på at eksamen MÅ leverast innan fristen som er sett, og må leverast via eksamensplattforma WISEFLOW. Det vil ikkje vere mogleg å få levert oppgåva etter fristen – det betyr at du bør levere i god tid slik at du kan ta kontakt med eksamenskontoret eller brukarstøtte om du har tekniske problem.

Då dette er ein heimeeksamen er det viktig å vise heilskapleg forståing, og oppgåvene har eit større preg av drøfting eller teknisk problemløsing. Det blir derfor forventa utfyllande og forklarande svar på alle teorioppgåver, og dokumentasjon i form av skjermbilde og tilhøyrande forklaringar til alle praktiske oppgåver. (Bilde som er vedlegg, men ikkje sett inn i svaret blir ikkje rekna som ein del av svaret.)

Det blir presisert at studenten skal svare på eksamen sjølvstendig og individuelt, samarbeid mellom studentar og plagiat er ikkje tillate. Det er ikkje tillate å presentere andre sitt arbeid som ditt eige – dette inkluderer arbeid utført av kunstig intelligens (som tekst- eller kode-genereringsmodellar). All bruk av tekst, bilde og illustrasjonar som er henta frå førelesingar, lærebøker eller internett skal førast med kjeldetilvising slik at det kjem tydeleg fram kva som er studenten sitt eige arbeid, APA7-standarden skal brukast for kjelder. For topp score bør svara underbyggast med relevante kjelder utover ordinær pensumlitteratur. Det bør sjølvstøtt og refererast til pensumlitteratur når dette er relevant.

OBS: Dei 4 teorioppgåvene (oppgåve 1 – 4) skal ikkje vere på meir enn 12 A4-sider, med fontstorleik 12, normale margar og linjeavstand 1.0. I tillegg til teorioppgåvene kjem dei praktiske oppgåvene (dei praktiske oppgåvene inngår ikkje i sidetalet på 12 sider, som berre gjeld for teorioppgåvene samla).

Teori oppgåver og drøftingar

Oppgåve 1 – Etisk hacking (10 %)

For ein som jobbar innan informasjonssikkerheit er det viktig å forstå kva ein etisk hackar er, kva ein sikkerheitstest er, og korleis rolla som etisk hackar passar inn i sikkerheitsorganisasjonen. Ein etisk hackar må vere i stand til å forklare dette tydeleg til ulike lag i organisasjonen, men også andre tilsette må kunne vite kva tid og til kva ein kan bruke etiske hackarar, enten innleigd eller i eigen organisasjon.

Svaret må underbyggast med relevante kjelder. Svar som ikkje har korrekt gjeve opp kjeldereferanse på APA7-format vil ikkje oppnå poeng. Kjeldelista skal gjevast opp for kvar deloppgåve separat.

Oppgåveformulering:

Du har nettopp starta i ny jobb i avdelinga for IT-sikkerheit i eit stort konsulentselskap. Forklar for ein (tenkt) arbeidsgjevar kvifor selskapet burde tilby kundane sine å gjennomføre ein «penetrasjonstest» av selskapa sine. Forklar kva ein etisk hackar betyr, kva rolla til ein etisk hackar er, og korleis dette spelar inn i ein sikkerheitsorganisasjon.

Oppgåve 2 – Cyberspace (5 %)

«Cybersikkerheit» tar meir og meir over som omgrep for å forklare bransjen vår, som også namnet på dette studiet viser, det er difor viktig å forstå kva som ligg i dette omgrepet, og å kunne drøfte forskjellane mellom omgrep som «cyberspace» og «internett».

Svaret må underbyggast med relevante kjelder. Svar som ikkje har korrekt gjeve opp kjeldereferanse på APA7-format vil ikkje oppnå poeng, ei av kjeldene må vere «Forsvarets fellesoperative doktrine» og omgrepa brukte der må drøftast opp mot andre kjelder. Kjeldelista skal gjevast opp for kvar deloppgåve separat.

Oppgåveformulering:

Drøft omgrepa «cyberspace» og «cybersikkerheit», forklar bakgrunnen for omgrepa og forklar kvifor dette omgrepet er viktig i rolla til ein etisk hackar.

Oppgåve 3 – Fysiske einingar (15 %)

Når ein skal gjennomføre ei meir avansert red team-øving kan det vere interessant å bruke fysiske einingar som ein del av angrepssimuleringa. For ein etisk hackar er det difor essensielt å ha god oversikt over dei ulike verktøya som er tilgjengelege for å kunne forstå kva som er best eigna til ulike oppgåver. I denne oppgåva skal du vise at du greier å omsetje det du har lært om avanserte angrepssimuleringar og fysiske verktøy til ein heilskapleg plan om bruk av slike verktøy.

På denne oppgåva må svaret innehalde minimum ein referanse til relevant kapittel i pensumlitteraturen, minimum ein referanse til ein youtube-video som forklarar bruk av ei av einingane du har valt å bruke (minutt og sekund inn i videoen skal gjevast opp), og minimum ein annan referanse. Svar som ikkje har korrekt gjeve opp kjeldereferanse på APA7-format vil ikkje oppnå poeng. Kjeldelista skal gjevast opp for kvar deloppgåve separat.

Oppgåveformulering:

Denne oppgåva er todelt. I den første delen skal du samanlikne ein tabell som inneheld minimum 6 fysiske einingar som er spesielt godt eigna for / laga konkret for avansert angrepssimulering eller penetrasjonstesting. Tabellen skal innehalde følgjande informasjon; namn på eininga, pris på eininga, URL til kvar eininga kan kjøpast inn, og ei kort skildring av bruksområdet i eininga (30 – 60 ord).

I den andre delen av oppgåva skal du lage og beskrive ein plan for å gjennomføre ei red team-øving med fysiske element, i denne planen skal du forklare korleis du kan bruke desse fysiske einingane som skildra over (minimum 4 av einingane skal brukast). For å få best poengoppnåing på denne oppgåva bør planen enten kombinerast med social engineering på ein fornuftig måte, eller einingane bør brukast i eit «kjeda angrep» der kvar fase brukar ei eining og byggjer på resultatet i tidlegare fase. Planen bør vere så konkret som mogleg og

rette seg mot eit anerkjent norsk selskap – men det blir presisert at angrepet ikkje skal gjennomførast eller testast i praksis (dette er den teoretiske delen av eksamen).

Oppgåve 4 – Analyse av hackarangrep (20 %)

Som ein etisk hackar vil ein ofte bli beden om ei ekspertutsegn om eit hackarangrep som har fått fokus i media, du skal i denne oppgåva difor vise at du er i stand til å tileigne deg ny kunnskap, setje dette i kontekst til ein angripar/hackar, og forklare dette vidare med eigne ord.

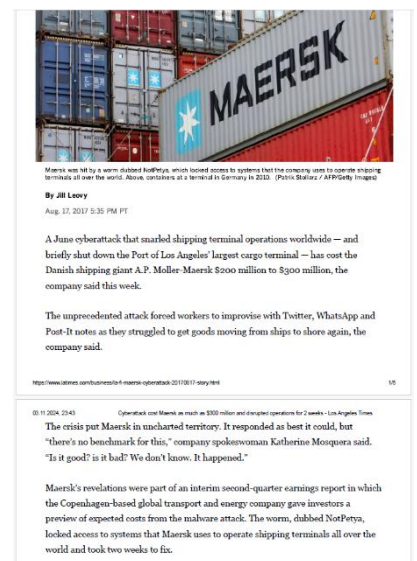
I denne oppgåva skal du vise at du greier å fordjupe deg i eit emne, og raskt finne kjelder med relevant informasjon.

På denne oppgåva må svaret ditt innehalde minimum ein referanse til artikkelen som er linka under og minimum to andre referansar.

Svar som ikkje har korrekt gjeve opp kjeldereferanse på APA7-format vil ikkje oppnå poeng. Kjeldelista skal gjevast opp for kvar deloppgåve separat.

Ein oppdragsgjevar sender deg følgjande artikkel frå Los Angeles Times, forfatta av Jill Leovy 17. august 2017 (artikkelen er òg lagt ved eksamensoppgåva på Canvas som PDF-fil):

<https://www.latimes.com/business/la-fi-maersk-cyberattack-20170817-story.html>



Oppgåveformulering:

Set deg inn i hackarangrepet som råka Maersk i 2017, som det blir vist til i artikkelen over. Du som tekniskar må òg søkje fleire meir tekniske kjelder på eiga hand og skrive ei fylldig skildring av angrepet. Skildringa di bør innehalde informasjon om KORLEIS angrepet vart gjennomført, KVEN som stod bak angrepet, og KVA som vart skadefølgjene av angrepet.

Du skal vidare forklare for den tenkte oppdragsgjevaren minimum 3 tiltak for å sikre at oppdragsgjevar ikkje (enkelt) blir offer for eit tilsvarande angrep.

Praktiske oppgåver

Oppgåve 5 – Exploit med Metasploit (10 %)

I denne oppgåva skal du vise at du kan gjennomføre eit enkelt angrep med eit exploit frå metasploit mot ein sårbar sørvar. Du skal demonstrere dei faktiske verktøya du brukar og dokumentere korleis du har gått fram for å løyse oppgåva, inklusive skjermbilde og kommandoar du har køyrt.

I denne oppgåva skal du bruke maskin med Kali Linux og Metasploit. Som «offer»-maskin skal du bruke den virtuelle maskina Metasploitable 2. Metasploitable 2 VMen skal vere sett opp i samsvar med øvingsoppgåve i veke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktoy).

Oppgåveformulering:

Du skal først starte Metasploitable 2 VM. Denne oppgåva består av 3 steg.

Det første steget er at du skal køyre NMAP mot alle portar på Metasploitable 2, og vise kva VERSJON av FTP-sørvar som køyrer på den VMen. Dokumenter med skjermbilde av NMAP og forklar kva versjonsnummer du har funne.

I steg to skal du frå Kali Linux starte verktøyet Metasploit, du skal ved hjelp av Metasploit starte eit shell på «offer»-maskina, og opprette ein ny brukar. Brukarnamnet skal vere KANDIDATNUMMERET DITT på denne eksamenen, og med eit valfritt passord. *Du opprettar ein ny brukar ved å skrive «useradd -m 999» følgd av «passwd 999» for å setje passord for brukaren, der 999 blir erstatta av KANDIDATNUMMERET DITT på denne eksamenen.*

I det tredje steget skal du restarte Metasploitable 2 VMen og logge deg inn med den nyoppretta brukaren, dokumenter med skjermbilde av Metasploitable 2 at du har fått oppretta ny brukar.

Oppgave 6 – Mimikatz og passordangrep (10 %)

I denne oppgåva skal du vise at du kan gjennomføre eit passord-angrep mot ei Windows-maskin. Angrepet knekk passord for ein kompromittert brukar.

I denne oppgåva skal du bruke maskin med Kali Linux. Som «offer»-maskin skal du bruke den virtuelle maskina «Bengts Windows VM». Windows VMen skal vere sett opp i samsvar med øvingsoppgåve i veke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktoy), slide 64 til 78. I tillegg skal VMen ha tilleggsprogramvare og konfigurasjon som sett opp i:

- *veke 42 (ETH2100_U42_Øvingsoppgaver_IntoTheRabbitHole_Exploits), slide 8 til 10,*
- *veke 44 (ETH2100_U44_Øvingsoppgaver_PasswordEqualsGod) slide 6 til 12, og*
- *veke 45 (ETH2100_U45_Øvingsoppgaver_DeepIntoTheRabbitHole) slide 7 til 25.*

Oppgåveformulering:

Du skal starte opp Windows VM, og logge deg inn som Administrator. Denne oppgåva består av 3 steg.

Det første steget er at du skal opprette ein ny brukar. Brukarnamnet skal vere bokstaven T følgd av KANDIDATNUMMERET DITT på denne eksamenen, og passordet skal setjast til sunshine.

I steg to skal du logge deg inn som den nye brukaren, og laste ned og køyre verktøyet Mimikatz på Windows VMen.

I det siste steget skal du kopiere output frå Mimikatz over til Kali Linux, og i Kali skal du bruke verktøyet John the Ripper til å knekke passordet basert på brukaren sin NTLM hash.

Kvart steg i prosessen må dokumenterast med skjermbilde, skjermbilda må setjast inn på riktig stad i svaret ditt og prosessen må forklarast med tekst.

Oppgave 7 – XSS angrep med BeeF (15 %)

I denne oppgåva skal du vise at du kan gjennomføre eit standard angrep med Browser Exploitation Framework (github.com/beefproject/). I ein enkel pentest er det normalt å berre bevise at XSS angrep fungerer ved å køyre eit enkelt Javascript (til dømes ein alert), men i ei meir omfattande Red Team-øving er det ofte nødvendig å faktisk hente ut informasjon frå maskina til offeret, eller plante ei bakdør eller ein trojanar. BeeF er eit rammeverk som kan vere eit mogleg val for å få meir ut av ein XSS sårbarheit.

Du skal demonstrere at du meistrar oppsett, konfigurasjon og deployering av BeeF-verktøyet, og du skal dokumentere korleis du har gått fram for å løyse oppgåva, inklusive skjermbilde og kommandoar du har køyrt.

I denne oppgåva skal du bruke maskin med Kali Linux, og du skal bruke webserveren Damn Vulnerable Web Application (og undersida "XSS Reflected", med security sett til Low), og som «offer» kan du velje å bruke di eiga fysiske host-maskin (eller eit anna VM om du føretrekkjer det). DVWA VMen skal vere sett opp i samsvar med øvingsoppgåve i veke 35 (ETH2100_U35_Øvingsoppgaver_Kali_VirtLab.pptx).

Oppgåveformulering:

Du skal setje opp BeeF på di Kali-maskin (om du ikkje allereie har det), og setje opp eit Reflected XSS-angrep mot websørvaren. Frå «offer»-maskina skal du starte ein nettlesar og gå til den XSS-sårbare websørvaren.

Du skal redigere config.yaml-fila til BeeF og endre namnet på hook_file til å vere kandidatnummeret ditt på denne eksamenen – følgd av filendinga ".js", slik (døme for kandidat nummer 10042):

```
# Hook
hook_file: "/10042.js"
hook_session_name: "BEEFHOOK"
```

I svaret ditt skal du vise oppstart og køyring av BeeF, du skal dokumentere korleis du utfører XSS-angrepet, og du skal vise både skjermbilde av BeeF som køyrer på Kali, og du skal vise

at du koplar deg på administrasjonsgrensesnittet til BeeF og greier å sjå at «offer»-maskina har vorte hacka. I BeeF skal du vise at du får opp nettlesaren din som eit offer, og du skal ta eit skjermbilde av Details-fana som viser verdiane `browser.window.origin`, `browser.window.cookies` og `browser.window.hostname`. Kva er offeret sin `PHPSESSIONID`?

Oppgåve 8 – Pivoting og PrivEsc (15 %)

I denne oppgåva skal du vise at du kan gjennomføre eit avansert angrep der du skal gjennomføre «pivot» (lateral movement) for å flytte deg frå den første sårbare sørvaren til ein annan sørvar på innsida av nettverket. Du skal òg oppnå «Manager»-rettar.

Du skal vidare demonstrere at du greier å handtere verktøy som kan brukast i eit redteam-opppdrag for å unngå at du blir oppdaga av sensorane til eit Security Operations Center.

Oppgåva består av fleire fasar, og det er spesifikke krav til kvar fase for å simulere angrepet, du skal demonstrere dei faktiske verktøya du brukar og dokumentere korleis du har gått fram for å løyse oppgåva, inklusive skjermbilde og kommandoar du har køyrt. Kvar del skal ha ei underoverskrift i svaret ditt som «Del A», «Del B» og så vidare, og fasane byggjer på kvarandre som gjer at dei må gjerast i riktig rekkefølge.

I denne oppgåva skal du bruke maskin med Kali Linux. Som «offer»-maskin «nummer 1» skal du bruke den virtuelle maskina «Bengts Windows VM». Windows VMen skal vere sett opp i samsvar med øvingsoppgåve i veke 37

(ETH2100_U37_Øvingsoppgaver_Pentest_Verktoy), slide 64 til 78. I tillegg skal VMen ha tilleggsprogramvare og konfigurasjon som sett opp i:

- veke 42 (ETH2100_U42_Øvingsoppgaver_IntoTheRabbitHole_Exploits), slide 8 til 10,*
- veke 44 (ETH2100_U44_Øvingsoppgaver_PasswordEqualsGod) slide 6 til 12, og*
- veke 45 (ETH2100_U45_Øvingsoppgaver_DeeperIntoTheRabbitHole) slide 7 til 25.*

Som «offer»-maskin «nummer 2» skal du bruke den virtuelle maskina som var brukt i arbeidskravet (Arbeidskrav VM). Arbeidskrav VMen skal vere sett opp i samsvar med oppgåva i veke 37 (ETH2100_U37_Arbeidskrav_ETH2100).

Desse to virtuelle maskinene må vere kopla til det same nettverket, og standard oppsett for VMWare blir forventa brukt (der VMWare simulerer ein multiport repeater tilsvarande slik ein Hub fungerer). Om du har gjort tilpassingar eller endringar i nettverksoppsettet du brukar i ditt lab-miljø må du ta omsyn til dette for å vere i stand til å fullføre oppgåva.

Oppgåveformulering:

DEL A (første fase i angrepet)

Du skal starte opp Windows VM, og logge deg inn som Administrator. Denne virtuelle maskina er sårbar ovanfor ei sårbarheit som heiter EternalBlue.

Det første steget er at du skal køyre NMAP mot VM for å sjekke om sørvaren er sårbar ovanfor EternalBlue-sårbarheita (hint: eit script i nmap kan gjere dette).

Frå Kali Linux skal du starte verktøyet Metasploit, du skal gjennom Metasploit utnytte EternalBlue-sårbarheit på Windows VMen. Du skal utnytte sårbarheita til å setje opp remote execution (psexec), eller eit reverse shell mot sørvaren.

DEL B (andre fase i angrepet)

Du skal så finne eit verktøy som allereie er installert i Windows som kan utnyttast for å gjennomføre Packet Capture på nettverket. Dette skal ha tilsvarande effekt som å installere Wireshark – men det blir spesifisert at studenten ikkje har lov til å laste ned Wireshark på Windows VMen (og heller ikkje bruke Wireshark om studenten har installert det der allereie under øvingstimane – i denne simuleringa vil bruk av Wireshark i denne delen trigge ein alarm). Dette verktøyet skal setjast i capture modus, og verktøyet må startast gjennom Metasploit frå Del A.

DEL C (simulering av aktivitet frå brukar)

Du skal så starte opp Arbeidskrav VMen, og du skal kople deg til websørvaren med ein nettlesar. Nettlesaren skal køyre på Windows VMen (då det er pivot frå denne maskina vi no simulerer), på Windows VMen har du sjølv sett passord for Administratorbrukar (det er

tinkerbell om du har same passord som sett i øvingsoppgåvene). Frå Windows VM skal du kople deg til websørvaren på Arbeidskrav VMen, klikke Login, og logge deg inn med brukarnamn mnguyen og passordet 27sfbdi.

Ver obs på at for å få brukt Internet Explorer på Windows VMen kan det tilrådest å skru av Enhanced Security, om du ikkje allereie har gjort dette.

DEL D (tredje og siste fase i angrepet)

For å avslutte angrepet skal du no hente ut Packet Capture frå Windows VMen, det må gjerast gjennom Metasploit du brukte i Del A, men elles er framgangsmåten valfri. Det er opp til deg korleis du ønskjer å gjere det og kvar du ønskjer å eksfiltrere data til – men det blir presisert at det må gjerast gjennom Metasploit (og til dømes ikkje ved å logge inn «fysisk» på Windows.)

Du skal konvertere denne Packet Capture-fila til å bli kompatibel med PCAP-filformatet, og skal så opne fila i Wireshark. Dette kan gjerast på host-maskina eller i Kali Linux. I Wireshark skal du finne HTTP-pakka som inneheld innlogginga og dokumentere med skjermbilde at du har funne passordet i klartekst – og med det demonstrere at du har gjennomført elevering av privilegium (til Manager-rolla på offer «maskin 2»).

-

Slutt på oppgåvesettet.